

Universidad de la
Defensa Nacional

FADENA

Ciberseguridad aplicada

Clase 2: Bloque Fundamentos

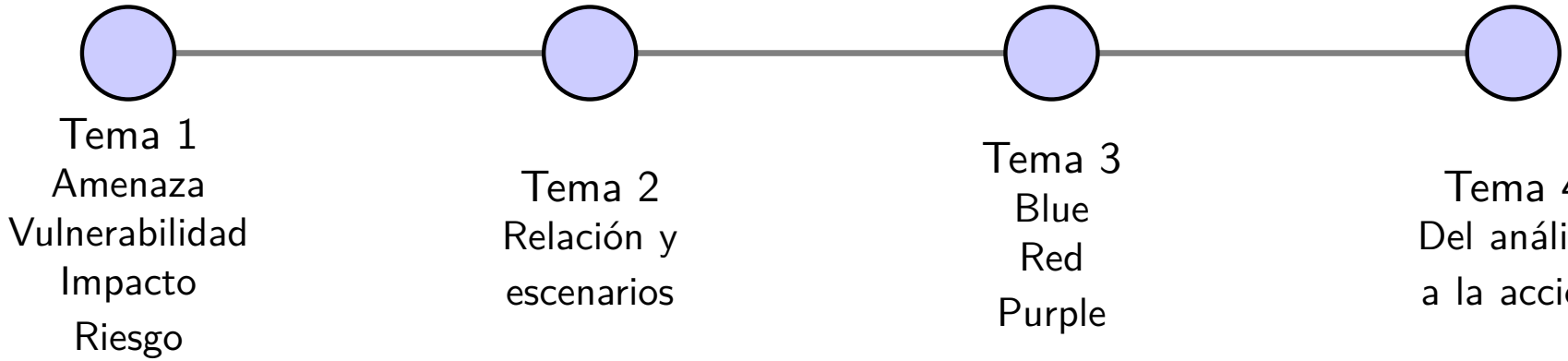
Unidad III: Riesgos y Amenazas

24 de agosto de 2026

Ruta de la Clase 2 : Unidad I a III

UNIDAD I	**UNIDAD II**	**UNIDAD III**
Espacio cibernético y conceptos fundamentales	Datos, información y propiedades de la Seguridad de la Información	Amenazas, vulnerabilidades y riesgo  Usted está aquí

Recorrido de la Unidad III



Tema 1 Amenaza, vulnerabilidad, impacto y riesgo
Tema 2 Relación entre conceptos y escenarios
Tema 3 Enfoques en ciberseguridad
Tema 4 Del análisis a la acción

Amenazas

¿Qué es una amenaza?

- Evento o acción que puede producir daño o pérdida de información
- Puede afectar el estado de seguridad de un activo

Idea clave

No todas las amenazas son ataques: también pueden ser errores o fallas.

Ejemplos

- Corte de energía
- Error de configuración
- Acceso no autorizado

Clasificación de amenazas

Accidentales

- Fallas físicas o técnicas
- Interrupción de servicios
- Eventos naturales

Errores

- Errores de uso o diseño
- Fallas en procesos o control

Intencionales (internas)

- Acceso no autorizado
- Alteración o destrucción
- Uso indebido de recursos

Intencionales (remotas)

- Interceptación (MITM)
- Suplantación
- Modificación de datos

Ahora que entendemos qué es una amenaza, veamos algunos ejemplos típicos de amenazas en el espacio cibernético.

Amenazas comunes

- Phishing
- Malware y ransomware
- Fuerza bruta
- Ingeniería social



Phishing

- **¿Qué es?** Suplantación de identidad para robar información (emails, SMS, redes).
- **Ejemplo:** Te llega un correo de "tu banco"pidiéndote que verifiques tu cuenta.
- **Señales de alerta:**
  - Correos con urgencia o amenazas ("¡Tu cuenta será suspendida!")
  - Errores ortográficos o direcciones raras.
  - Links que no coinciden con el dominio real.

Phishing

- **¿Cómo se evita?**
  - No hacer clic en enlaces sospechosos o urgentes.
  - Verificar siempre el remitente y la URL.
  - Nunca compartir contraseñas por mail o redes.





Malware y Ransomware

- **¿Qué es?** Software malicioso que infecta dispositivos. El ransomware cifra tus archivos y pide rescate.
- **Ejemplo real:** WannaCry (2017) afectó hospitales y empresas enteras.
- **¿Cómo entra?**
  - Archivos adjuntos
  - Links falsos
  - Sitios infectados



Fuerza bruta

- **¿Qué es?**
  Ataque basado en probar múltiples combinaciones de contraseñas hasta adivinar la correcta.
- **Ejemplo:**
  Acceso a cuentas de correo con contraseñas débiles como 123456 o `admin`.
- **¿Cómo se evita?**
  - Usar contraseñas largas y complejas (mínimo 12 caracteres).
  - Activar el doble factor de autenticación (2FA).
  - No repetir contraseñas entre distintas plataformas o servicios.

¿Qué es la Ingeniería Social?

La **Ingeniería Social** es el arte de manipular a las personas para que revelen información confidencial o realicen acciones que comprometan la seguridad. A diferencia de los ataques puramente técnicos, se enfoca en la explotación de factores humanos como la confianza, el miedo o la urgencia.
Los ingenieros sociales usan el conocimiento del comportamiento humano, las emociones y el contexto para lograr sus objetivos.

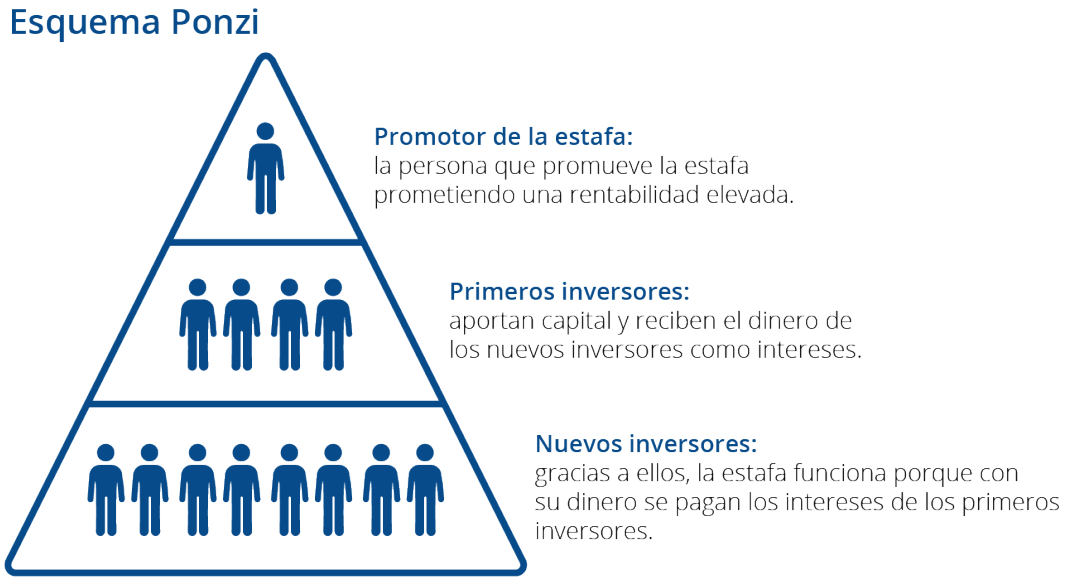
Victor Lustig – El hombre que vendió la Torre Eiffel

En 1925, Victor Lustig convenció a un empresario para que le comprara la Torre Eiffel como chatarra. Se hizo pasar por funcionario del gobierno francés, falsificó documentos oficiales y utilizó técnicas clásicas de persuasión para ganar la confianza de su víctima. Incluso fingió aceptar un soborno para reforzar su credibilidad. La víctima, avergonzada, nunca denunció la estafa. Lustig repitió el intento una segunda vez antes de desaparecer.



Carlo Ponzi – El esquema que lleva su nombre

Carlo Ponzi prometía retornos del 50 % en 45 días mediante una supuesta inversión en cupones postales. Pagaba a los primeros inversores con el dinero de los nuevos, sin generar ninguna ganancia real.
La clave de su éxito fue la confianza que inspiraba. Su esquema colapsó en 1920, y Ponzi fue encarcelado. Desde entonces, este tipo de fraude piramidal lleva su nombre.



Frank Abagnale Jr. – El impostor encantador

Antes de cumplir 21 años, Abagnale se hizo pasar por piloto de Pan Am, médico, abogado y profesor universitario. Su arma principal era el carisma, la observación del entorno y la confianza que generaba con su actitud.

Fue detenido en Francia y, tras cumplir condena, trabajó como consultor para el FBI. Su vida fue llevada al cine en la película *Atrápame si puedes*.



Kevin Mitnick – El hacker que usó la voz

Mitnick combinó técnicas de hacking con Ingeniería Social. Llamaba a empleados haciéndose pasar por técnicos de soporte y obtenía información crítica como contraseñas.
Ingresó a sistemas de empresas y organismos como el NORAD y Sun Microsystems. Fue arrestado en 1995 y, tras cumplir condena, se convirtió en consultor en ciberseguridad. Su historia evidenció que el eslabón más débil en la seguridad no son los sistemas, sino las personas.

Ingeniería social

La Ingeniería Social no requiere habilidades técnicas avanzadas, sino comprensión del comportamiento humano. Estos casos históricos muestran cómo el engaño, la persuasión y la manipulación pueden superar incluso a los sistemas más sofisticados.

Vulnerabilidad e impacto

Vulnerabilidad

- Debilidad o condición que puede ser explotada por una amenaza
- Surge de la relación entre un activo y una amenaza
- Permite que la amenaza se materialice

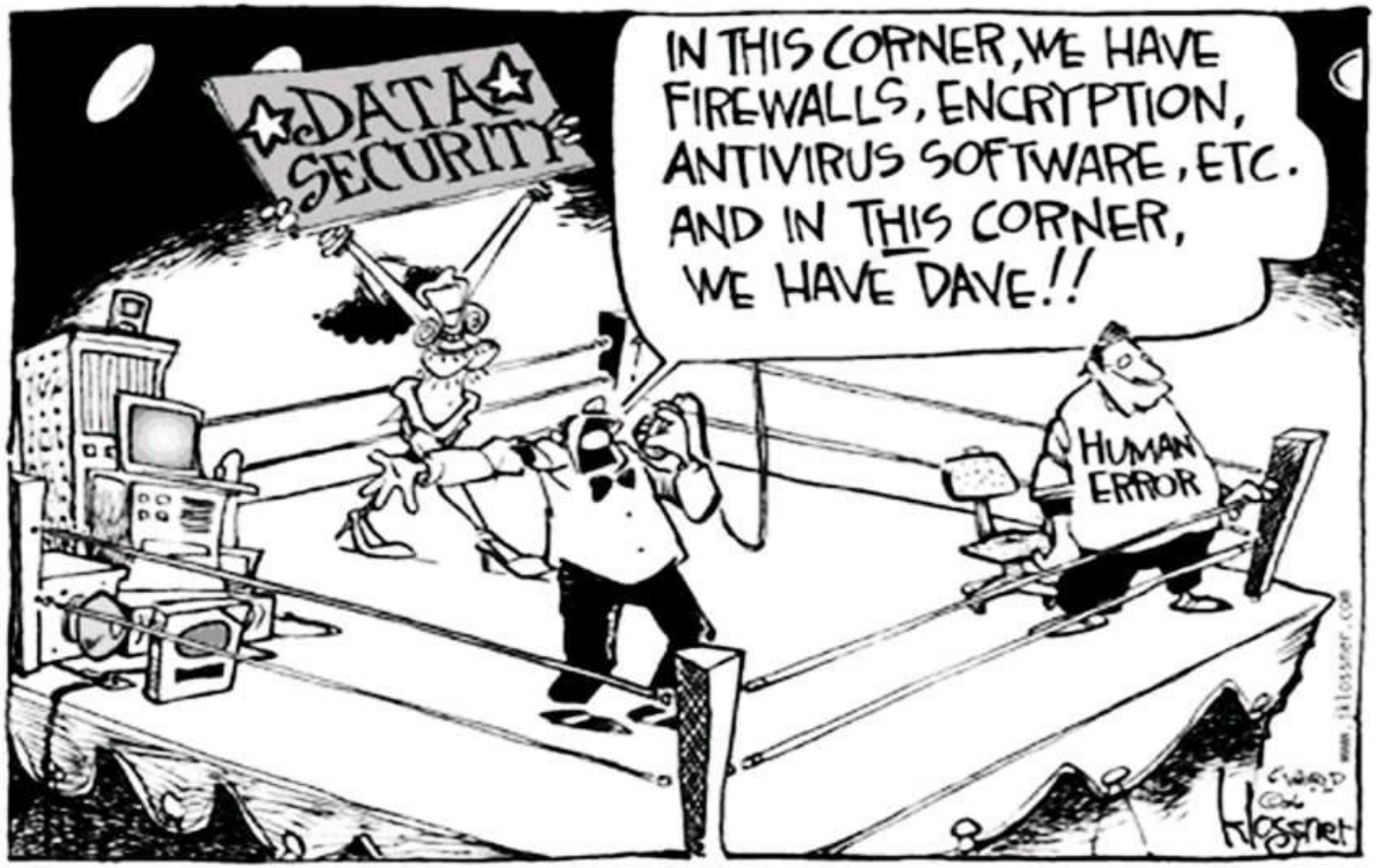
Impacto

- Consecuencia o daño producido sobre un activo
- Se observa cuando la amenaza se materializa

Idea clave

Sin vulnerabilidad, la amenaza no puede generar impacto.

Vulnerabilidades humanas



Ejemplos de vulnerabilidades humanas

- Uso de contraseñas débiles o reutilizadas
- Falta de actualización de conocimientos o concientización en seguridad
- Exceso de confianza o ausencia de verificación ante solicitudes inusuales
- Descuidos en el manejo de información sensible

Las vulnerabilidades humanas son una de las principales causas de incidentes de seguridad.

Definiciones de riesgo según organismos internacionales

ISO (International Organization for Standardization)

- "El riesgo es el efecto de la incertidumbre sobre los objetivos" [1]

IIA (Institute of Internal Auditors)

- "La posibilidad de que ocurra un evento que tenga un impacto en el logro de los objetivos. El riesgo se mide en términos de impacto y probabilidad" [2]

NIST (National Institute of Standards and Technology)

- "El riesgo es una medida del grado en que una entidad está amenazada por un evento, función del impacto adverso y la probabilidad de ocurrencia" [3] [4]

Riesgo

- Posibilidad de que una amenaza explote una vulnerabilidad
- Se expresa en términos de:
  - Probabilidad de ocurrencia
  - Impacto sobre el activo

Tipos de riesgo

- **Riesgo intrínseco:** sin controles
- **Riesgo residual:** luego de aplicar controles

Otros conceptos

- **Umbral de riesgo:** nivel aceptable
- El riesgo puede propagarse entre activos

Idea clave

El riesgo combina probabilidad e impacto.

Relación entre amenaza, vulnerabilidad e impacto

$$\text{Amenaza} \rightarrow \text{Vulnerabilidad} \rightarrow \text{Impacto}$$

- **Amenaza:** evento que puede causar daño
- **Vulnerabilidad:** debilidad que puede ser explotada
- **Impacto:** consecuencia sobre el activo

Relación entre conceptos

$$\text{Amenaza} \rightarrow \text{Vulnerabilidad} \rightarrow \text{Impacto}$$

$$\textbf{Riesgo} = \textbf{Probabilidad} + \textbf{Impacto}$$

Idea clave

El riesgo representa la posibilidad de que una amenaza explote una vulnerabilidad y genere un impacto.

Enfoques operativos en ciberseguridad

- En ciberseguridad moderna se utilizan distintos equipos con roles complementarios.
- Estos enfoques están basados en marcos reconocidos como NIST [5].
- Permiten:
  - Prevenir ataques
  - Detectar intrusiones
  - Mejorar la respuesta ante incidentes
- Los tres enfoques principales son: Blue Team, Red Team y Purple Team.

Blue Team (Defensa)

- El **Blue Team** se encarga de la defensa de los sistemas.
- Su objetivo es proteger la infraestructura tecnológica siguiendo buenas prácticas de seguridad [6].
- Funciones principales:
  - Monitoreo de redes y sistemas
  - Detección de incidentes
  - Respuesta ante ataques
  - Implementación de controles de seguridad
- En resumen: son los "guardianes" de la organización.

Red Team (Simulación de ataque)

- El **Red Team** simula ataques reales de manera controlada.
- Se basa en técnicas reales de adversarios documentadas en MITRE ATT&CK [7].
- Actividades típicas:
  - Pentesting
  - Ingeniería social controlada
  - Evaluación de vulnerabilidades
- Su objetivo es encontrar fallos antes que atacantes reales.

Purple Team (Colaboración)

- El **Purple Team** integra Red Team y Blue Team.
- Promueve la colaboración y el intercambio de hallazgos [8].
- Objetivos:
  - Mejorar detección de ataques
  - Optimizar la respuesta
  - Fortalecer la seguridad global
- Enfoque clave: mejora continua conjunta.

Comparación general

- Blue Team: defensa y monitoreo [6]
- Red Team: simulación de ataques [7]
- Purple Team: colaboración y mejora continua [8]

Objetivo común: mejorar la seguridad de los sistemas y reducir riesgos.

Del concepto a la práctica

- Ya comprendimos qué son las amenazas, vulnerabilidades, impactos y riesgos
- Estos conceptos describen cómo ocurre un **incidente** [1] de seguridad
- Sin embargo, estos conceptos por sí solos no son suficientes en la práctica

[1] Una amenaza se convierte en incidente cuando logra materializarse sobre una vulnerabilidad en la organización, generando un impacto real

Un problema no trivial

Identificar amenazas y vulnerabilidades no es un proceso automático: ¿Cómo los encontramos dentro de una organización real?
Requiere analizar la organización, su entorno y su funcionamiento, y sobre todo: saber qué preguntas hacer.

Problema a resolver

Para poder gestionar la seguridad, primero debemos estudiar la organización y su entorno para poder identificar estos elementos de forma estructurada.

En la próxima clase (clase 3) estudiaremos cómo se realiza este proceso mediante la gestión de activos (Unidad IV) y la gestión de riesgos (Unidad V).

¡¡Muchas gracias!!

Volvemos al campus virtual y
por favor realizen la Actividad
Obligatoria
de esta Semana,

Fecha límite:
Lunes 31/08 23:59 hs



Referencias I


International Organization for Standardization.
Iso 31000:2018 risk management, 2018.


Institute of Internal Auditors.
International professional practices framework (ippf).
https://actuaries.org/app/uploads/2025/08/IAARiskBook_RiskAndUncertainty_2017-06.pdf.


National Institute of Standards and Technology.
Guide for conducting risk assessments (sp 800-30 rev.1).
https://csrc.nist.gov/publications/detail/sp/800-30/rev-1/final, 2012.


National Institute of Standards and Technology.
Nist glossary: Risk.

Referencias II


National Institute of Standards and Technology.
Framework for improving critical infrastructure cybersecurity, 2018.


Iso/iec 27001: Information security management systems, 2022.
Norma internacional de gestión de seguridad de la información.


MITRE Corporation.
Mitre attck framework.
https://attack.mitre.org, 2025.
Accedido en 2026.

Referencias III


European Union Agency for Cybersecurity (ENISA).
Enisa threat landscape.
https://www.enisa.europa.eu/topics/cyber-threats/threat-landscape, 2024.
Accedido en 2026.